

Formal methods as a path to machine-checked intent

Evidence from an applied campaign across 158 open-source codebases

August 2026

The thesis

Software fails when what it does drifts from what it was meant to do. Nearly every other property is downstream of that one.

A compiler proves that code is well-formed. A test proves the one behaviour somebody thought to write down. A static analyser proves the absence of a fixed catalogue of known-bad patterns. None of them knows what the code was *supposed* to do, because until recently there was no way to tell a machine that at scale.

Intent has always existed in a form machines could not read. It sits in documentation and specifications, in RFCs and protocol papers, in interface annotations and docstrings, in the project's own test names, and most usefully of all in the sibling function three screens down that handles the same concern correctly. Converting that material into a precise, checkable claim was human work, and it did not scale.

Language models changed the input side of the problem. They read all of it.

What they cannot do on their own is separate a real divergence from a plausible-sounding one. A model asked to find bugs will produce candidates indefinitely, with stated confidence largely uncorrelated to correctness and no internal mechanism for rejecting its own output. This is why AI-assisted code review has acquired a reputation for volume over signal, and why maintainers of several large projects have started refusing AI-generated reports on sight.

Formal methods supply the missing half. Once intent has been recovered as an explicit property, it can be adjudicated. The property is reproduced by executing the real shipped code, and where its shape permits, discharged by machine-checked proof against a semantic model, with a deliberately false control claim run alongside so that a passing proof is known not to be vacuous.

Language models to recover intent. Formal methods to adjudicate it. The claim under test was that this combination finds real defects in code its operators did not write, and stays quiet when there is nothing to find.

What was run

The Formal Verification Kit was applied to 158 third-party open-source codebases over roughly two months. None of the targets were written by anyone involved, and none had any commercial relationship to the work. They span nine languages and four domains.

Targets were not selected for being weak. The set includes Uniswap, Aave, EigenLayer, LayerZero, Polymarket, Wormhole, Avalanche, Keycloak, HashiCorp Vault, PyTorch and pandas: heavily used, heavily audited, in several cases carrying dozens of prior professional audits.

DOMAIN	CODEBASES	WITH A DEFECT	CLEAN
Blockchain protocols and infrastructure	60	20	40
Agent and LLM platforms	56	44	12
Identity, authorisation and policy	30	12	18
Language libraries and frameworks	12	9	3
Total	158	85	73

Results

85 of the 158 codebases yielded at least one genuine defect. 73 came back clean. Counting the highest-severity finding in each codebase:

SEVERITY	CODEBASES	MEANING
P0	1	Security control fully defeated, code execution reachable
P1	12	Funds, credentials or data directly at risk from an unprivileged actor
P2	23	Exploitable under realistic conditions, or bounded privilege escalation
P3	26	Real but conditional, narrower blast radius
P4	15	Correctness or trust-boundary defect, limited exploitation path
P5	1	Hardening only, not permissionlessly exploitable
unrated	7	Confirmed defect, no priority assigned
Total	85	

Two of the P1 results are recorded as likely rather than confirmed. In the proof-carrying subset, every finding was reproduced by executing the released package at a pinned version confirmed byte-identical to the upstream commit, and twelve carry a negative-controlled machine-checked proof. Five of the 158 targets turned out to have little or no reviewable production code, being documentation repositories, test utilities or sample projects; they are retained in the counts above and identified in the appendix.

The most important number is the one that came back empty

73 of 158 codebases produced nothing exploitable. In the subset where every stage of the funnel was recorded, 31 candidates were raised and 13 were refuted before shipping.

STAGE	COUNT
Candidates raised	31
Survived adversarial culling	18
Confirmed and shipped	16
Refuted	13

The refutations are specific and were paid for with real work. A claimed floating-point tolerance defect in a major numerical library was disproved by installing the library and measuring the actual value. A finding reported against a widely used web framework by an earlier pass was overturned as intended, documented behaviour, with the maintainer's own pull request and committed test as the evidence. Findings against two further libraries were withdrawn against release notes and committed tests. Elsewhere in the campaign, five candidates against one framework and four against another were raised and then knocked down.

This is the property that distinguishes the approach commercially. A tool that never returns "nothing here" cannot be trusted when it returns something, and cannot be put in front of a maintainer twice. Trustworthy negatives are the scarce good in this market, and they follow directly from the adjudication step rather than from prompt tuning.

Three findings, and why they are the same finding

Locations and reproduction steps are withheld throughout. What matters here is the shape.

An attestation gate that never checks the attestation

A confidential-computing project gates access to protected groups on a hardware attestation quote. The entire security value of that design rests on verifying the quote's signature against the hardware vendor's certificate chain. The implementation parses the quote and never verifies it. The verification routine it belongs to is named for a check it does not perform, and the library it calls exposes the correct method immediately alongside the one used. The consequence is that a peer with no trusted hardware at all can present a quote and be admitted.

A mint that trusts an account nobody validated

A cross-chain token portal mints new supply when it receives an attested inbound transfer. Its account validation constrains every account involved except one: the destination that ultimately receives the minted tokens. The two sibling operations in the same program, for sending and for unwrapping, both enforce the constraint that this path omits. The result is that a permissionless participant can redirect newly minted supply while the internal ledger continues to credit the intended recipient, leaving the system short.

A security scanner that asks the suspect what to search

An agent platform scans untrusted community extension bundles before installing them. The scanner honours an exclusion list shipped *inside the bundle it is scanning*. A bundle can therefore suppress the findings about itself, including critical structural ones. The verdict flips from dangerous to safe, no override prompt is shown, and the

excluded payload is still installed and executed, because the one file that cannot be excluded is the manifest, and the manifest instructs the agent to run it. Reproduced against the real imported module across two dozen bypass configurations and confirmed present in the project's main branch. This was the campaign's only P0.

These three sit in unrelated languages, ecosystems and threat models. They are the same defect. In each case the codebase states its own intent unambiguously, in a function name, a protocol specification, or a sibling that implements the identical concern correctly, and the implementation contradicts it. No pattern-matching rule would catch any of them, because there is no bad pattern present. What is present is a contradiction, and contradictions are what a proof system is built to expose.

The shapes that recur

Across 158 unrelated codebases, a small number of shapes accounted for most confirmed defects. This matters more than any individual bug, because a recurring shape is a target for automation.

Correct sibling, broken sibling. The single most common shape. A project implements a concern properly in one place and omits it in another. A rebalancing function missing the role gate its sibling carries. A state accessor skipping an ownership check the equivalent handler performs correctly one file away. An archive extractor validating an entry's name but not its link target. The intent here is not merely documented, it is executable and sitting in the same repository.

Substring where exact matching was meant. Concentrated in the identity and authorisation stack. Several independent projects accept a scope string that merely contains the characters of the required scope as though it granted that scope. Several others use raw prefix comparison for path allowlists, so a permitted directory silently authorises its siblings.

Guards defeated at a boundary. The guard exists, is correct, and is bypassed by something outside its frame. One project validates a destination address and then follows redirects without re-checking. Another never calls its own guard on one of its components. Two more lose their allowlists to redirects or rebinding.

Archive extraction escapes. The same containment failure in three unrelated products, two of them sandboxing services whose entire purpose is containment.

Continuous integration as the live attack surface. On protocol repositories, the most reachable code execution was frequently not in the contracts at all. Several projects run untrusted fork pull requests on self-hosted runners with shell and filesystem access enabled. In one case the project's own separate workflow carries the guard the vulnerable ones lack.

How a run works

One. Recover intent. Derive what the code is supposed to do from sources independent of the code itself: documentation, specifications, annotations, the project's own tests, and sibling implementations of the same concern. The claim under investigation is always "this code contradicts what its own project says it does", never "this line looks suspicious".

Two. Attack the candidate. Every candidate is handed to independent reviewers whose task is to refute it. Most candidates die here. That is the design working, not the design failing.

Three. Adjudicate. Survivors are reproduced by executing the real code at a pinned version confirmed byte-identical to upstream. Where the property permits, the core logic is modelled in the K framework and discharged with a

prover, alongside a deliberately false control claim that must fail for the result to count.

Four. Package. Each confirmed finding is recorded with the quoted intent source it violates, the test gap that let it through, a runnable reproduction, and a proof artifact graded for strength.

Limits

Stated plainly, because a report of this kind is worth less without them.

Large codebases were scoped to their highest-risk surfaces rather than cleared line by line, and every such result in the appendix records what was and was not covered. A clean verdict means clean within the reviewed scope and never more than that.

Where a machine-checked proof is present, it is a proof over a distilled model of the defect's core logic, not over the shipped source. The line-level correspondence to real code is carried by the executed reproduction. Four of the sixteen proofs in the proof-carrying subset are labelled explicitly weaker than the rest, with the reproduction named as the load-bearing evidence rather than the proof. No proof in the set uses a trust annotation to paper over a gap.

Two P1 results are recorded as likely rather than confirmed. One codebase was reviewed twice under different scopes and returned different verdicts; the appendix records the more severe. Severity ratings are the reviewers' own and were not adjudicated by the affected projects. Findings date from a two-month window and were not re-checked against current upstream state, so some may since have been fixed. This is a research campaign measuring a method, not a substitute for a commissioned audit.

Appendix. Every codebase reviewed

Worst gives the highest-severity finding in that codebase. "none" means nothing exploitable was found within the reviewed scope. "unrated" means a defect was confirmed but no priority assigned. An asterisk marks a result recorded as likely rather than confirmed. Locations and reproduction steps are withheld; they are available to the affected projects on request.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
Oxsequence/wallet-contracts	Solidity/Huff	none	No exploitable defect in the reviewed scope. Wallet logic clean; build-chain pinning hardening only.
aave/aave-v4	Solidity	none	No exploitable defect in the reviewed scope. Oracle staleness is by design and admin-gated. CI workflow pinning hardening only.
ACINQ/eclair	Scala	none	No exploitable defect in the reviewed scope. CI hardening only. Funds-custody core was scope-mapped rather than cleared line by line.
activepieces/activepieces	TypeScript	none	No exploitable defect in the reviewed scope. Residual coverage gap in tool authorisation and project permissions.
agent-infra/sandbox	Python/TypeScript	P4	A provider returns exception objects on failed lifecycle operations, so callers treat cleanup and start failures as successes.
agno-agi/agno	Python	P3	Scoped non-admin users can omit an owner identifier and create global records visible to other users.
agno-agi/scout	Python	P2	A debug query binds the user identity from request data rather than the authenticated principal, and a pattern-only write guard misses several write forms.
All-Hands-AI/OpenHands	Python	P3	A pending-message endpoint lets an authenticated user inject messages into another user's starting conversation.
Alongside-Finance/amkt-v2	Solidity	none	No exploitable defect in the reviewed scope. Value and privilege paths are role-gated with an explicit solvency check. Strongest divergence is documentation describing an accrual the owner-gated setter never performs.
alt-research/mach-avs	Solidity	P3	An off-by-one in a deletion loop reads out of bounds, so a valid disproof of a non-latest alert can never be recorded.
anza-xyz/agave	Rust	none	No exploitable defect in the reviewed scope. Vote and consensus safety, fee and rent accounting and builtin programs reviewed. Very large codebase, deliberately scoped to highest risk.
apache/casbin	Go	P3	Path matchers build patterns from policy strings without escaping, so a policy authorises sibling paths it was never meant to cover.
argoproj/argo-cd	Go/TypeScript	none	No exploitable defect in the reviewed scope. Namespace filters, pattern matching and project namespace boundaries reviewed.
authelia/authelia	Go/TypeScript	none	No exploitable defect in the reviewed scope. Redirection domain checks, redirect validation and session cookie domain matching use exact or label-boundary comparison.
authzed/spicedb	Go	none	No exploitable defect in the reviewed scope. Schema import path validation and authorisation candidates reviewed with no reproducible defect.
ava-labs/avalanchego	Go	none	No exploitable defect in the reviewed scope. Consensus, staker verification, reward arithmetic and signature handling read line by line and found overflow-safe. Very large codebase, deliberately scoped to highest risk.
axelarnetwork/axelar-gmp-sdk-solidity	Solidity	none	No exploitable defect in the reviewed scope. Replay guard, signature malleability, weighted threshold and governance timelock all match documented intent.
baerae-zkap/zkap-contracts	Solidity	none	No exploitable defect in the reviewed scope. Each identified gap has an in-contract mitigation.
BerriAI/litellm	Python	none	No exploitable defect in the reviewed scope. Residual coverage gap in the proxy route authorisation slice.
better-auth/better-auth	TypeScript	none	No exploitable defect in the reviewed scope. Token exchange, redirect validation, admin role updates, domain matching and key surfaces reviewed with no reproducible defect.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
browser-use/browser-use	Python	P3	Certain document types bypass the allowed and prohibited domain checks, risking exposure of globally configured sensitive data.
bytechefhq/bytechef	Java	none	No exploitable defect in the reviewed scope. Hardening only: an authorisation token is fetched but not validated on one path.
bytedance/deer-flow	Python	P3	Non-admin users can mutate global skills and therefore influence global agent behaviour.
caddyserver/caddy	Go	none	No exploitable defect in the reviewed scope. Admin API remote access path, host and origin checks use exact match or segment boundary.
casdoor/casdoor	Go	P3	User information scope checks use substring matching, so tokens holding unrelated custom scopes receive protected profile fields.
celo-org/celo-monorepo	Solidity/TS/Go	none	No exploitable defect in the reviewed scope. Stable-asset core read line by line. Two off-chain accounting discrepancies, both governance-gated.
centrifuge/protocol	Solidity	none	No exploitable defect in the reviewed scope. One reproduced CI configuration defect where a test profile inherits shell access on fork pull requests.
Chainlit/chainlit	Python	none	No exploitable defect in the reviewed scope. Hardening only: with authentication disabled, session identifiers act as bearer capabilities.
cheshire-cat-ai/core	Python	P3	Wildcard cross-origin configuration reflects arbitrary origins with credentials, enabling cross-origin reads and writes against cookie-authenticated sessions.
chronicleprotocol/aggor	Solidity	none	No exploitable defect in the reviewed scope. One price source does not reject a zero value, reachable only under a deployer-fixed degenerate configuration combined with a dual oracle outage.
cline/cline	TypeScript	P2	Repository-local hooks execute by default, enabling code execution from a malicious workspace.
cloudflare/sandbox-sdk	TypeScript	P4	An archive restore path can write entries outside the intended workspace, bypassing workspace-only restore semantics.
code-payments/code-android-app	Kotlin	none	No exploitable defect in the reviewed scope. A committed debug signing key bounded to the debug identity. Server-side and dynamic analysis out of scope.
ComposioHQ/composio	Python	P2	Upload paths fetch supplied addresses before validating them, so loopback, private and metadata targets are reachable.
continuedev/continue	TypeScript	P4	Mutating remote-configuration commands are classified as requiring no permission because the parent command is broadly allowlisted.
CopilotKit/CopilotKit	TypeScript	P3	Event and state endpoints drop the resolved user boundary.
coze-dev/coze-studio	Go	P3	Expired personal access tokens still authenticate protected API requests.
crewAIInc/crewAI	Python	P1	An outbound-request guard validates the initial destination and then follows redirects unchecked. Separately, an archive extractor validates entry names but not link targets, and a recovery branch is unreachable.
dagger/container-use	Go	unrated	The environment identifier is a policy-level selector rather than an enforced per-session binding, and current-environment state is process-global.
danny-avila/LibreChat	JavaScript	P2	Action updates can retarget saved credentials and tokens to a new server.
datahaven-xyz/datahaven	Rust/Substrate+Solidity	P3	Staging and test validator sets run on well-known public development keys as live genesis authorities.
daytonaio/daytona	TypeScript	unrated	Stale cached visibility can keep private previews open, and revoked tokens stay accepted until cache expiry.
dexidp/dex	Go	none	No exploitable defect in the reviewed scope. Redirect and scope handling, refresh downscoping and certificate reload candidates reviewed.
elastic/elasticsearch-py	Python	P2	Query parameter keys are interpolated without escaping, and identifiers reach the query language unescaped, both allowing injection.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
Elenpay/NodeGuard	C#	P2	An API token is stored in a form that is itself a working bearer credential, so read access to the datastore yields withdrawal-capable credentials.
EnsoBuild/shortcuts-client-contracts	Solidity	none	No exploitable defect in the reviewed scope. Identified gaps are neutralised by protocol behaviour or by additive checks.
EspressoSystems/espresso-network	Rust/Solidity	none	No exploitable defect in the reviewed scope. Funds-out paths clean. Cryptographic soundness deferred to the project's own audits.
etherfi-protocol/smart-contracts	Solidity	none	No exploitable defect in the reviewed scope. A committed API key in a deploy-script comment and an event field mismatch. Integration math not exhaustively verified.
expressjs/express	JavaScript	none	No evidence-backed defect above P4. Documentation and hardening findings retained around error handlers, routing pitfalls and proxy trust assumptions.
fastapi/fastapi	Python	none	No exploitable defect in the reviewed scope. A header-handling candidate reported by an earlier pass was refuted as intended, documented behaviour.
FhenixProtocol/fhenix-toolkit	MD/CI	none	No exploitable defect in the reviewed scope. Documentation and plugin package with no runtime source; the only executable surface is two CI workflows.
flashbots/mosaik	Rust	P1	A hardware attestation gate parses the attestation and never verifies its signature, so a peer with no trusted hardware joins protected groups. Two consensus defects compound it.
FlowiseAI/Flowise	TypeScript	P2	A custom connection path can bypass the outbound deny-list through redirects or rebinding.
FraxFinance/public-frax-bamm	Solidity	none	No exploitable defect above P4. Collateral, borrow, liquidation and interest accounting reviewed with no reproduced solvency break.
gelatodigital/relay-context-contracts	Solidity	none	No exploitable defect in the reviewed scope. The trusted-forwarder gate fails closed and calldata decoders are correctly conditioned. Documentation references undeclared modifiers.
getnao/sylph	Markdown/Agent	P4	Several shipped skills can perform outbound actions through connectors despite a documented drafts-only boundary.
go-gitea/gitea	Go	none	No exploitable defect in the reviewed scope. Redirect matching, loopback client exceptions and scope membership use exact normalised comparison.
goauthentik/authentik	Python/Go/TypeScript	P4	Reply validation compares scheme and host correctly but still uses raw prefix comparison on the path, so a configured endpoint also accepts sibling same-origin paths.
grafana/grafana	Go/TypeScript	P3	Provisioning path validation uses raw prefix comparison, so a permitted base directory also accepts sibling directories and reads or writes escape the configured base.
graphql/graphql-js	TS/JS	P3	Cyclic fragments in a validation rule recurse until the stack overflows, giving a denial of service on the validator.
hashicorp/vault	Go	none	No exploitable defect in the reviewed scope. Namespace parent and prefix handling canonicalised before comparison; no reproducible defect.
Helicone/helicone	TypeScript	none	No exploitable defect in the reviewed scope. Residual coverage gap in provider-key vault permissions and organisation isolation.
helm/helm	Go	none	No exploitable defect in the reviewed scope. Archive loading and expansion reject parent, absolute and platform-specific escape paths.
hyperliquid-dex/contracts	Solidity	none	No exploitable defect in the reviewed scope. Bridge withdrawal signature and quorum verification, validator-set updates and staking reviewed clean.
iExecBlockchainComputing/PoCo	Solidity	none	No exploitable defect in the reviewed scope. Escrow, staking, consensus and signed order matching inspected clean.
infiniflow/ragflow	Python	P4	Authenticated users can create or upload under a known unauthorised parent identifier, causing cross-tenant storage pollution.
jmoiron/sqlx	Go	P2	Placeholder rewriting alters content inside string literals, producing incorrect generated statements. A second defect mishandles Unicode parameter names.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
keycloak/keycloak	Java	none	No exploitable defect in the reviewed scope. Redirect matching, request-object audience checks and client URI policy logic reviewed.
labring/FastGPT	TypeScript	none	No exploitable defect in the reviewed scope. API key management and proxy authentication controls reviewed clean.
langchain-ai/langchain	Python	P2	A user-supplied value is placed into a pattern without escaping, causing crashes and false negatives. Two further parsing and merge defects corrupt prompt handling and metadata.
langchain-ai/langgraph	Python	P1	A state reducer leaks an internal wrapper object into user-visible state.
langflow-ai/langflow	Python	P1	Command validation can be bypassed by relocating dangerous tokens into a multi-word field. A separate finding: a search component fetches agent-controlled addresses without calling the project's own guard.
langfuse/langfuse	TypeScript	none	No exploitable defect in the reviewed scope. Residual coverage gap in public API scoping and connection tenant isolation.
langgenius/dify	Python/TS	P2	Cross-tenant tag update and delete through identifier-only service queries.
Lay3rLabs/TrustGraph	Solidity/Rust	P2	Hook registration has no access control, so any account can register a reverting hook that freezes all future state-root updates.
LayerZero-Labs/LayerZero-v2	Solidity	none	No exploitable defect in the reviewed scope. Every documented gate in the scoped verification, quorum, nonce and fee paths is enforced.
Layr-Labs/eigenlayer-contracts	Solidity	none	No exploitable defect in the reviewed scope. Share and withdrawal-queue accounting, beacon proof verification and slashing reviewed. Very large audited codebase, deliberately scoped.
lifinance/create3-factory	Solidity	none	No exploitable defect in the reviewed scope. Per-deployer salt namespacing structurally prevents same-chain hijack and front-running.
lightsparkdev/grid-api	TS/MDX	P3	Sample client computes a webhook signature verdict and then ignores it, accepting forged events. Sample code only, no production server.
linera-io/linera-protocol	Rust	P4	A CI workflow reads untrusted pull request data into an authenticated API call, allowing comment forgery under the project identity.
lobehub/lobe-chat	TypeScript	P3	Revoked API keys remain authenticated from cache for several minutes.
logto-io/logto	TypeScript	P3	Scope validation uses substring matching, so a token carrying an unrelated scope containing the required characters is accepted as holding it.
m0-foundation/solana-portal	Rust/Anchor	P1	Inbound cross-chain transfers mint to a caller-supplied account that validation never constrains, while sibling instructions enforce that constraint correctly.
malbeclabs/doublezero	Rust/Solana+Go	P2	A state accessor validates a type discriminant but never account ownership, so a forged state account grants allowlist control. The sibling handler checks it correctly.
maple-labs/contract-test-utils	Solidity	none	No exploitable defect in the reviewed scope. Test-utility library with no production surface. A shell-quoting issue in its own tooling is developer-local.
mastra-ai/mastra	TypeScript	unrated	A fail-open authentication boundary: default-auth custom routes can execute unauthenticated when the route authorisation map is not derived from registered routes.
mcp-use/mcp-use	TypeScript	P2	The proxy target allow-list can be bypassed with redirects.
mezo-org/musd	Solidity	none	No exploitable defect in the reviewed scope. Collateral accounting, liquidation ordering, stability-pool math and mint authority reviewed clean.
microsoft/presidio	Python	P2	Falsy wrong-typed values bypass a type validator entirely, so validation silently passes on malformed input.
Mintplex-Labs/anything-llm	JavaScript	P4	Thread middleware can mutate a user's thread from a workspace they no longer have access to.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
mitosis-org/chain	Go	P5	An unbounded event value could overflow a narrowing conversion, but the trigger is owner-gated and not permissionlessly reachable.
modelcontextprotocol/typescript-sdk	TypeScript	none	No exploitable defect in the reviewed scope. Hardening only: rebinding protection on direct transports is opt-in.
more-itertools/more-itertools	Python	none	No exploitable defect in the reviewed scope. Missing tests and underspecified documentation identified, nothing exploitable.
morpho-org/morpho-token	Solidity	none	No exploitable defect in the reviewed scope. Delegation and voting-power conservation reviewed clean. Ignored transfer return values are unreachable given the deployed assets.
n8n-io/n8n	TypeScript	P4	Partial credential updates can preserve an unavailable external-secret provider without provider-access validation.
nestjs/nest	TypeScript	none	No confirmed framework-level defect. Five high-risk boundary candidates were raised and disproven across guards, pipes, request scope and routing.
nevermined-io/docs	Markdown/CI	none	No exploitable defect in the reviewed scope. Documentation repository with no security-relevant runtime code.
NousResearch/hermes-agent	Python	P0	A security scanner honours an exclusion file shipped inside the untrusted bundle it is scanning, so a bundle can suppress every finding about itself, flip the verdict from dangerous to safe, and still install and execute its payload.
oak-network/sdk	TS/JS	none	No exploitable defect above P4. Signing, key handling and fee construction reviewed.
oauth2-proxy/oauth2-proxy	Go	none	No exploitable defect in the reviewed scope. Redirect validation, domain matching and provider scope augmentation reviewed. A substring scope candidate fails closed because membership is separately enforced.
onyx-dot-app/onyx	Python	P1*	Generated image and code-execution artifacts are treated as globally readable, so any authenticated user holding a file identifier can download another user's output.
open-policy-agent/opa	Go	none	No exploitable defect in the reviewed scope. Bundle signature scope and audience handling and related verification paths reviewed.
open-webui/open-webui	Python/TS	P3	Knowledge directory and file paths allow cross-directory references.
openfga/openfga	Go	none	No exploitable defect in the reviewed scope. A syntax-handling candidate was tested and current code rejects it.
openfort-xyz/7702-HELPER	Solidity/TS	none	No exploitable defect in the reviewed scope. Validation fails closed. One session-key configuration is created active but permanently inert.
opensandbox-group/OpenSandbox	Python	P3	A proxy tunnel endpoint is reachable without lifecycle authentication.
ora-io/opagent	Solidity	P2	A result-submission entry point is permissionless and never clears the request, so a finalised side-effecting callback can be replayed.
OrderlyNetwork/js-sdk	TS/JS	none	No exploitable defect above P4. A sign error in a liquidation-price estimate affects risk display for a single user, and CI logs echo secrets.
OriginProtocol/arm-oeth	Solidity	none	No exploitable defect in the reviewed scope. Two adapters over-report a received amount, but the only consumer discards the value.
ory/hydra	Go	none	No exploitable defect in the reviewed scope. Redirect, post-logout redirect, scope and audience checks reviewed.
ory/kratos	Go	P4	Allowlist path matching uses raw prefix comparison, so a permitted path also authorises sibling paths on the same host.
osabiohq/osabio	TypeScript	P2	Without an authentication header the proxy still accepts a workspace header into identity signals, injecting private workspace context after only an existence check.
overlay-market/v1-core	Solidity	P3	An unbounded backward oracle round walk reverts after a provider phase migration, temporarily halting market operations.
pallets/flask	Python	none	No exploitable defect in the reviewed scope. One datetime round-trip lossiness candidate was adjudicated a defect but held rather than shipped.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
pandas-dev/pandas	Python	P1	A guard intended to prevent lossy scalar conversion is a tautology, giving silent data corruption on assignment operations. Two further conversion defects.
Permify/permify	Go	none	No exploitable defect in the reviewed scope. Schema loading and permission lookup candidates reviewed; loading appears limited to development paths.
pewdiepie-archdaemon/odysseus	Python	P2	Values marked as encrypted are stored in cleartext at rest and decrypt to an empty string.
plumenetwork/nest-protocol	Solidity	none	No exploitable defect in the reviewed scope. Redemption surfaces are operator-trusted by design. A committed local test keypair and unpinned CI actions.
pocketbase/pocketbase	Go	none	No exploitable defect in the reviewed scope. Targeted review plus the project's own test suite produced no reproducible defect.
Polymarket/ctf-exchange-v2	Solidity	none	No exploitable defect in the reviewed scope. Order matching, settlement, signature handling and collateral conservation hand-verified.
prometheus/prometheus	Go	P3	Label remapping can create names that later validation would reject, after configuration validation has already accepted them.
pydata/xarray	Python	P1	A selection operation returns a result inconsistent with its documented shape contract.
pytorch/pytorch	Python	P1	A probability distribution accepts parameters outside its valid range under the default validation path.
rainlanguage/rain.extrospection	Solidity	none	No exploitable defect in the reviewed scope. Externally audited read-only introspection library; no intent-versus-code divergence found.
risechain/vrf-reference	Solidity/Rust	none	No exploitable defect above P4. Despite the name it is a signature-only oracle rather than a verifiable random function. An off-chain listener panics on an untrusted log field.
rivet-dev/sandbox-agent	Rust	P4	Archive extraction can write outside the selected destination through link semantics.
rome-protocol/evm	Rust	P3	A bytecode operation panics instead of returning zero for an out-of-range index, aborting execution and diverging from other implementations.
RooCodeInc/Roo-Code	TypeScript	P2	Project-local configuration in an untrusted workspace can auto-start external tool processes before tool approval applies.
run-llama/llama_index	Python	P4	Bound parameters excluded from the tool schema are merged into emitted result events, exposing secret-like values to logs and subscribers.
sandbox0-ai/sandbox0	Go	P4	A system token can resolve arbitrary tenants' egress credential bindings through a body-selected scope.
scroll-tech/usx-contracts	Solidity	P2	A rebalancing function is missing the role gate its sibling function carries, letting an unprivileged caller force treasury spending.
SeaQL/sea-orm	Rust	P3	An audit path for schema statements is unimplemented, so a restricted connection panics instead of returning an error.
sebadob/rauthy	Rust	P4	Scope sanitisation uses substring matching, so a custom scope containing the required characters is saved without the required grant.
SeismicSystems/moonhatch	Solidity/Rust	P1	A deployment entry point is publicly callable with no authorisation or state guard and moves pooled custody on each call. Backend routes are also unauthenticated.
SocketDotTech/socket-DL	Solidity	none	No exploitable defect in the reviewed scope. Inbound message verification, switchboard authorisation and fee paths reviewed clean.
SONGS-TOOLS/songs-protocol	Solidity	P1	Reward claim accepts a caller-supplied identifier with no membership check, letting an unprivileged account drain a shared pool repeatedly.
StartaleGroup/zk-nft-migration	Solidity	P4	Ownership transfer does not move the admin role, so a prior deployer retains withdrawal and mint rights after a documented handover. Trusted operators only.
storacha/w3infra	TS/JS	P3	An OAuth callback trusts an unverified issuer field and writes without an existence guard, so one verification can overwrite another customer's billing record.

REPOSITORY	LANGUAGE	WORST	ASSESSMENT
supabase/auth	Go	P3	Discovery validates the issuer address but not the endpoints the discovery document returns, so a public document can register private-network endpoints used by later fetches.
superagent-ai/vibekit	TypeScript	P2	Branch names and model-generated metadata are interpolated into shell commands, enabling command execution inside the sandbox and credential leakage.
superform-xyz/superform-core	Solidity/CI	P2	CI runs untrusted fork pull requests on a self-hosted runner with shell and filesystem access, giving code execution on project infrastructure.
taikoxyz/taiko-mono	Solidity/Go/Rust	P2	Two CI workflows run untrusted fork pull request code on self-hosted runners without the fork guard the project's own third workflow carries.
thesis/solidity-contracts	Solidity	none	No exploitable defect in the reviewed scope. Reusable library contracts with no deployed fund-handling surface.
traefik/traefik	Go	none	No exploitable defect in the reviewed scope. Path prefix boundary candidates and forwarded address handling reviewed; strict prefix generation uses segment boundaries where the specification requires it.
transact-rs/sqlx	Rust	P3	Schema-qualified type names are treated as equivalent to quoted identifiers, conflating different type-name structures.
triggerdotdev/trigger.dev	TypeScript	none	No exploitable defect in the reviewed scope. Residual hardening gap in queue and version-promotion tenant isolation.
Uniswap/universal-router	Solidity	none	No exploitable defect in the reviewed scope. Command dispatch, sweeps and transfers, permit handling and the reentrancy lock reviewed clean.
vercel/ai	TS/JS	P1*	Prompt and tool input and output are exported by default once telemetry is registered.
vercel/chat-sdk	TS/JS	unrated	Deduplication keys and normalised identifiers can omit workspace scope, write-tool approval is metadata rather than an execution guard, and unsigned webhooks are processed when no secret is configured.
vercel/eve	TS/JS	unrated	No per-session ownership on resume and stream routes, custom channels can skip route authorisation, and scheduled side effects rely on author idempotency.
vercel/next.js	JavaScript	unrated	A documented request body size limit is enforced on one runtime path and not the other, so oversized bodies are buffered past the configured cap.
vercel/workflow	TS/JS	unrated	Sanitised default exports can render version fragments instead of package names in display output.
VoltAgent/voltagent	TypeScript	P2	Remote execution can bypass legacy authentication and spoof the user identity in agent calls.
windmill-labs/windmill	Rust	none	No exploitable defect in the reviewed scope. Residual coverage gap in trigger webhook authentication.
wormhole-foundation/native-token-transfers	Solidity/Rust	none	No exploitable defect in the reviewed scope. Mint and burn authority, rate-limit accounting, attestation thresholds and recipient binding reviewed clean.
yamadashy/repomix	TypeScript	P3	Content flagged by the secret scanner is warned about but still included in generated output when history inclusion is enabled.
zitadel/zitadel	Go	none	No exploitable defect in the reviewed scope. Scope prefix namespaces, redirect equality and audience validation reviewed.
zkp2p/zkp2p-contracts	Solidity	none	No exploitable defect in the reviewed scope. Gating signatures lack a nonce and are replayable, but only by an already-authorised actor, and they auto-expire.